

PLATEFORME POS MULTI-ENTREPRISES

Cahier des charges

Administration centrale SaaS

Supervision globale, sécurité, paiements, quotas,
communications et préparation des abonnements

Version 1.0 — Document de référence

Généré le 27/08/2026

Cahier des charges — Administration centrale du SaaS POS

Version : 1.0

Date : 27 août 2026

Statut : proposition fonctionnelle et technique avant implémentation

1. Contexte

Le POS fonctionne désormais comme une application SaaS multi-entreprise. Les propriétaires administrent leur propre compagnie, tandis que le concepteur de la plateforme doit disposer d'un espace central lui permettant de superviser le service dans son ensemble.

Cet espace ne doit pas être confondu avec :

- le rôle `owner`, propriétaire d'une compagnie ;
- le rôle `admin`, administrateur interne d'une compagnie ;
- les pages actuellement placées dans `resources/views/admin`, qui servent principalement à la connexion et à l'inscription de l'application.

Le futur espace sera nommé **Administration SaaS** ou **Console plateforme**.

2. Constat sur l'existant

Le seeder `database/seeder/UserSeeder.php` crée actuellement le compte suivant :

- nom : `DIXON` ;
- adresse : `pakpalididier@gmail.com` ;
- ancien type utilisateur : `user_type = 1` ;
- mot de passe écrit directement dans le code du seeder.

Ce mécanisme ne suffit pas pour sécuriser une administration globale :

- `user_type` est un champ historique et ne représente pas clairement un rôle plateforme ;
- il n'existe pas encore de middleware réservé aux administrateurs SaaS ;
- le mot de passe ne doit pas rester dans le dépôt Git ;

- l'administration des compagnies et les statistiques existantes restent limitées au contexte d'une entreprise active.

Le compte existant pourra être migré comme premier **super-administrateur plateforme**, mais sans conserver un secret codé en dur.

3. Objectifs

La console doit permettre au concepteur de :

1. connaître l'état global du SaaS ;
2. consulter les entreprises, leurs propriétaires et leur activité ;
3. suivre les utilisateurs et leurs adhésions aux différentes compagnies ;
4. surveiller les paiements KPrimePay, quotas et consommations ;
5. détecter les échecs de notifications, jobs et webhooks ;
6. suspendre proprement un compte ou une compagnie en cas de besoin ;
7. consulter une piste d'audit de toutes les opérations sensibles ;
8. préparer la future gestion des abonnements sans imposer encore un plan tarifaire.

4. Types d'administrateurs plateforme

Une table et des permissions propres à la plateforme sont recommandées. Elles doivent être indépendantes des rôles de compagnie.

4.1 Super-administrateur

- accès complet à la console ;
- gestion des autres administrateurs plateforme ;
- suspension et réactivation des compagnies ou utilisateurs ;
- réglages globaux et opérations sensibles ;
- accès aux journaux d'audit.

4.2 Support

- consultation des compagnies, utilisateurs et incidents ;
- accès limité aux informations nécessaires au dépannage ;

- aucune modification de quota, aucun remboursement et aucun réglage global sans permission dédiée.

4.3 Finance

- paiements, quotas, chiffres d'affaires SaaS et exports ;
- aucune consultation inutile des données métier détaillées des entreprises.

4.4 Technique / exploitation

- queues, cron, webhooks, erreurs et santé du système ;
- aucune intervention commerciale ou financière par défaut.

5. Accès et sécurité

5.1 URL et authentification

- URL dédiée, par exemple `/platform/login` puis `/platform` ;
- aucun besoin de sélectionner une compagnie pour accéder à cette console ;
- middleware obligatoire `platform.admin` ;
- limitation des tentatives de connexion ;
- session séparée ou garde Laravel dédiée recommandée ;
- déconnexion et expiration après inactivité ;
- protection CSRF de toutes les actions web.

5.2 Compte initial

Le seeder doit lire les valeurs depuis l'environnement :

```
PLATFORM_ADMIN_NAME=  
PLATFORM_ADMIN_EMAIL=  
PLATFORM_ADMIN_PASSWORD=
```

En production, il est préférable d'utiliser une commande Artisan interactive et idempotente plutôt qu'un mot de passe dans le seeder, par exemple :

```
php artisan platform-admin:create
```

Le mot de passe initial devra être changé à la première connexion.

5.3 Renforcement recommandé

- double authentification TOTP ou code à usage unique ;
- confirmation récente du mot de passe pour toute action critique ;
- journalisation de l'adresse IP, appareil, date et résultat de connexion ;
- notification e-mail lors d'une nouvelle connexion administrative ;
- possibilité de révoquer toutes les sessions ;
- restriction IP optionnelle pour le super-administrateur.

6. Tableau de bord global

Le tableau de bord doit proposer des périodes : aujourd'hui, 7 jours, 30 jours, année et période personnalisée.

6.1 Indicateurs entreprises

- nombre total de compagnies ;
- compagnies actives, suspendues et nouvellement inscrites ;
- évolution des inscriptions ;
- compagnies ayant effectué une activité récente ;
- compagnies inactives depuis 7, 30 ou 90 jours ;
- nombre moyen d'utilisateurs par compagnie ;
- activation de la boutique e-commerce.

6.2 Indicateurs utilisateurs

- utilisateurs uniques ;
- utilisateurs actifs récemment ;
- nouveaux utilisateurs ;
- invitations en attente, acceptées, expirées et refusées ;
- utilisateurs appartenant à plusieurs compagnies ;
- comptes désactivés.

6.3 Activité métier agrégée

Ces données doivent être agrégées, sans exposer inutilement le détail commercial d'une entreprise :

- nombre de ventes ;
- volume monétaire total des ventes avec regroupement par devise ;
- nombre de commandes e-commerce ;
- taux de conversion commande vers vente ;
- nombre d'inventaires ;
- produits et clients enregistrés au total ;
- activité par jour ou par mois.

Les montants de devises différentes ne doivent jamais être additionnés sans conversion explicite.

6.4 Paiements et quotas

- paiements KPrimePay créés, en attente, réussis, refusés, expirés ou bloqués ;
- montant encaissé par période et par devise ;
- quantité de SMS et WhatsApp achetée ;
- quotas disponibles par compagnie ;
- consommations SMS et WhatsApp ;
- coût estimé, revenu et marge lorsque les données seront disponibles ;
- paiements nécessitant une réconciliation manuelle ;
- délai moyen entre checkout et confirmation.

6.5 Santé technique

- jobs en attente et échoués ;
- date de dernière exécution du cron ;
- derniers webhooks KPrimePay reçus ;
- taux d'échec e-mail, SMS et WhatsApp ;
- temps de réponse moyen des services externes si mesuré ;
- état de la base, stockage disponible et dernière sauvegarde connue ;
- version applicative actuellement déployée.

7. Modules de la console

7.1 Entreprises

Liste paginée avec recherche et filtres : nom, identifiant public, propriétaire, statut, pays, date de création, dernière activité, quotas et e-commerce.

La fiche compagnie doit afficher :

- informations principales et propriétaire ;
- membres et rôles, en lecture seule par défaut ;
- quotas et consommation ;
- paiements KPrimePay ;
- volumes agrégés de ventes, commandes et inventaires ;
- configuration des canaux ;
- incidents récents ;
- historique des suspensions et opérations administratives.

Actions sensibles : suspendre, réactiver, ajuster exceptionnellement un quota avec motif obligatoire. Toute action exige confirmation, loader dans le bouton et écriture dans l'audit.

7.2 Utilisateurs globaux

- recherche par nom, e-mail ou téléphone ;
- compagnies auxquelles l'utilisateur appartient ;
- rôle et statut dans chacune ;
- dernière connexion et dernière compagnie utilisée ;
- invitations et sessions ;
- désactivation/réactivation globale avec motif ;
- aucun affichage ni modification de mot de passe.

7.3 Paiements KPrimePay

- historique global paginé ;
- filtres par statut, compagnie, transaction, référence KPrimePay et période ;
- distinction entre montant demandé, frais et total ;
- détails du webhook normalisé V1/V2 ;

- état de crédit des quotas ;
- relance de vérification autorisée, idempotente et auditée ;
- aucun crédit manuel silencieux.

7.4 Communications

- statistiques e-mail, SMS et WhatsApp ;
- succès, échecs et attente par catégorie vente/inventaire ;
- consommation par compagnie ;
- recherche dans les journaux techniques sans exposer les secrets ;
- relance contrôlée d'un envoi échoué lorsque cela est sûr ;
- masquage partiel des numéros et adresses pour les rôles support limités.

7.5 Exploitation

- jobs échoués avec exception résumée, date, tentative et compagnie ;
- relance unitaire ou groupée avec confirmation ;
- statut des tâches planifiées ;
- incidents de webhook ;
- consultation des erreurs applicatives filtrées et nettoyées des secrets ;
- page de maintenance globale facultative.

7.6 Abonnements — préparation future

Même si les plans seront définis plus tard, prévoir dès maintenant les emplacements suivants :

- catalogue de plans ;
- abonnement d'une compagnie ;
- période d'essai ;
- statut : essai, actif, en retard, suspendu, annulé ;
- limites fonctionnelles ou quantitatives ;
- historique des changements ;
- factures et paiements d'abonnement futurs.

Ce module peut rester désactivé tant que les règles tarifaires ne sont pas validées.

7.7 Paramètres plateforme

- nom et identité visuelle de l'application ;
- coordonnées du support ;
- modification du prix unitaire des SMS et des messages WhatsApp ;
- activation globale des services externes ;
- délais d'expiration et paramètres non secrets ;
- modèles de notifications plateforme ;
- aucune clé API affichée entièrement dans l'interface.

Gestion des prix unitaires de communication

Le super-administrateur doit pouvoir modifier séparément :

- le prix unitaire d'un SMS ;
- le prix unitaire d'un message WhatsApp ;
- la devise de facturation, initialement **XOF** ;
- éventuellement une date d'entrée en vigueur programmée.

Règles obligatoires :

- prix entier positif exprimé dans la plus petite unité facturée, sans valeur négative ;
- affichage de l'ancien prix, du nouveau prix et du montant total simulé avant confirmation ;
- confirmation du mot de passe récent pour la modification ;
- motif obligatoire ;
- journalisation de l'administrateur, de la date, de l'ancienne valeur et de la nouvelle valeur ;
- absence d'effet rétroactif sur les checkouts et paiements déjà créés ;
- le prix appliqué doit être enregistré sur chaque ligne de paiement afin de conserver l'historique exact ;
- invalidation du cache de configuration après validation ;
- loader dans le bouton et protection contre les doubles clics ;
- permission dédiée **platform.pricing.manage**.

Les valeurs **.env** actuelles pourront servir de valeurs initiales ou de secours, mais les nouveaux tarifs administrables devront être conservés en base de données dans des paramètres plateforme. Les services de checkout ne devront plus lire uniquement **KPRIMEPAY_SMS_UNIT_PRICE** et **KPRIMEPAY_WHATSAPP_UNIT_PRICE** une fois cette évolution mise en production.

7.8 Journal d'audit

Enregistrer au minimum :

- administrateur ;
- action ;
- ressource et identifiant ;
- ancienne et nouvelle valeur pour les modifications autorisées ;
- motif ;
- adresse IP et user-agent ;
- date ;
- résultat réussi ou échoué.

Le journal ne doit pas être modifiable depuis l'interface.

8. Assistance et accès exceptionnel à une compagnie

Une fonction « voir comme cette entreprise » peut être utile, mais elle est risquée. Elle devra respecter les règles suivantes :

- permission plateforme spécifique ;
- motif obligatoire ;
- durée limitée ;
- bandeau permanent indiquant le mode assistance ;
- lecture seule par défaut ;
- aucune vente, suppression, paiement ou modification sensible en mode lecture ;
- journalisation du début, des pages consultées et de la fin ;
- retour immédiat à la console plateforme.

Cette fonctionnalité ne fait pas partie du premier MVP recommandé.

9. Protection des données multi-entreprise

- la console utilise explicitement des requêtes globales réservées au middleware plateforme ;
- les routes ordinaires continuent obligatoirement d'appliquer le contexte de compagnie ;
- aucune suppression en cascade d'une compagnie depuis une simple liste ;

- privilégier suspension et archivage à la suppression physique ;
- masquer les données personnelles selon le rôle plateforme ;
- ne jamais exposer les mots de passe, tokens, signatures de webhook ou clés API ;
- exporter uniquement les colonnes nécessaires et journaliser les exports administratifs.

10. Ergonomie attendue

- interface responsive, utilisable sur ordinateur et tablette ;
- menu distinct de celui du POS ;
- cartes de statistiques, graphiques légers et tableaux paginés côté serveur ;
- filtres conservés pendant la navigation ;
- états vides, erreurs et chargements clairement affichés ;
- badges cohérents : vert succès/actif, orange attente, rouge échec/suspendu ;
- boutons d'export regroupés dans un accordéon ou menu dédié ;
- toute attente serveur affiche le loader global et bloque les doubles clics conformément à [docs/UI_CONVENTIONS.md](#).

11. Exigences de performance

- pagination serveur obligatoire sur les listes globales ;
- index sur statuts, dates, `company_id`, `user_id` et références de paiement ;
- agrégations SQL et absence de chargements N+1 ;
- cache court des statistiques globales lourdes ;
- chargement asynchrone des graphiques ;
- périodes limitées par défaut ;
- exports volumineux traités en job et notifiés à la fin.

12. Architecture technique proposée

Nouveaux éléments possibles :

- table `platform_admins` ou tables `platform_roles`, `platform_permissions` et pivot associé ;
- middleware `EnsurePlatformAdmin` ;
- contrôleurs sous `App\Http\Controllers\Platform` ;

- vues sous `resources/views/platform` ;
- routes nommées `platform.*` ;
- table `platform_audit_logs` ;
- service de statistiques plateforme ;
- commande `platform-admin:create` ;
- tests Feature dédiés à l'accès global et au refus des utilisateurs ordinaires.

Une garde Laravel distincte est préférable pour réduire le risque qu'un rôle de compagnie soit confondu avec un rôle plateforme.

13. Découpage conseillé

Phase 1 — MVP sécurisé

- compte super-administrateur sécurisé ;
- garde et middleware plateforme ;
- tableau de bord global essentiel ;
- liste et fiche des compagnies ;
- liste et fiche des utilisateurs ;
- paiements et quotas ;
- paramètres plateforme et modification sécurisée des prix unitaires SMS/WhatsApp ;
- audit des connexions et actions ;
- tests d'autorisation.

Phase 2 — Exploitation

- communications et délivrabilité ;
- jobs échoués, cron et webhooks ;
- alertes et réconciliation contrôlée ;
- exports administratifs.

Phase 3 — Gouvernance commerciale

- plans et abonnements ;
- essais, limites et facturation ;

- indicateurs financiers SaaS ;
- rôles support, finance et technique détaillés.

Phase 4 — Assistance avancée

- accès temporaire et traçable en lecture seule à une compagnie ;
- centre d'incidents ;
- automatisation des alertes et rapports périodiques.

14. Tests d'acceptation principaux

1. Un utilisateur ordinaire ou propriétaire de compagnie reçoit un refus sur toutes les routes `platform.*`.
2. Le super-administrateur accède à la console sans compagnie active.
3. Les statistiques globales comptent plusieurs compagnies sans mélanger les affichages métier dans le POS.
4. Une suspension prend effet immédiatement et reste réversible.
5. Chaque action sensible exige une confirmation et produit une entrée d'audit.
6. Deux clics rapides ne déclenchent jamais deux opérations.
7. Un paiement déjà crédité ne peut pas recréditer les quotas.
8. Les secrets et mots de passe ne sont jamais visibles dans les pages, exports ou logs d'audit.
9. Les listes restent paginées et rapides avec un grand volume de données.
10. Le compte initial doit changer son mot de passe et activer le second facteur selon la politique retenue.
11. Un changement tarifaire affecte uniquement les nouveaux checkouts et conserve les anciens montants.
12. Un administrateur sans la permission `platform.pricing.manage` ne peut ni modifier ni soumettre un tarif.

15. Critères de livraison du MVP

Le premier lot sera considéré terminé lorsque :

- l'accès plateforme est totalement séparé des rôles de compagnie ;
- le mot de passe du seeder a disparu du code ;

- le tableau de bord, les compagnies, utilisateurs, paiements et quotas sont consultables ;
- les actions autorisées sont confirmées, protégées contre les doubles clics et auditées ;
- les prix SMS et WhatsApp sont modifiables de manière sécurisée et historisée ;
- les tests d'accès et de non-régression passent ;
- une recette multi-compagnie est validée sur staging ;
- la procédure de création et de récupération du compte plateforme est documentée.

16. Décisions à valider avant développement

- nom affiché de la console : **Administration SaaS** ou **Console plateforme** ;
- activation obligatoire de la double authentification dès le MVP ;
- possibilité ou non de suspendre globalement un utilisateur ;
- présence de l'accès temporaire en lecture seule dès la phase 1 ou en phase 4 ;
- durée de conservation des journaux d'audit ;
- indicateurs financiers visibles avant la définition des abonnements.

Recommandation finale

Commencer par la phase 1 et ne pas réutiliser directement le rôle **admin** d'une compagnie. Le compte indiqué dans le seeder peut devenir le premier super-administrateur, mais sa création doit passer par une commande sécurisée ou des variables d'environnement, avec changement obligatoire du mot de passe et idéalement une double authentification.